420-1C2-DW · THREATS AND RISKS · CLASS 10

Measuring Risk: Likelihood, Impact, Complexity and Spread

Topic 5 — Assessing Probability and Impact (Part 1)



Friday, November 13, 2026 · 6:00 pm – 10:00 pm · online

AEC (Attestation d'études collégiales) Cybersecurity: Prevention and Intervention (LEA.D8)

Cyber.SoHo Educational Hub — Asen Grozdanov

Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved. For use in an isolated, authorized lab environment only, against the targets this exercise designates. Applying these tools or techniques to any other system, network or data without the owner's express written authorization may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1) and 184) and is strictly prohibited. You alone are responsible for your actions and your equipment. Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy, v2.0, section 7.

Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

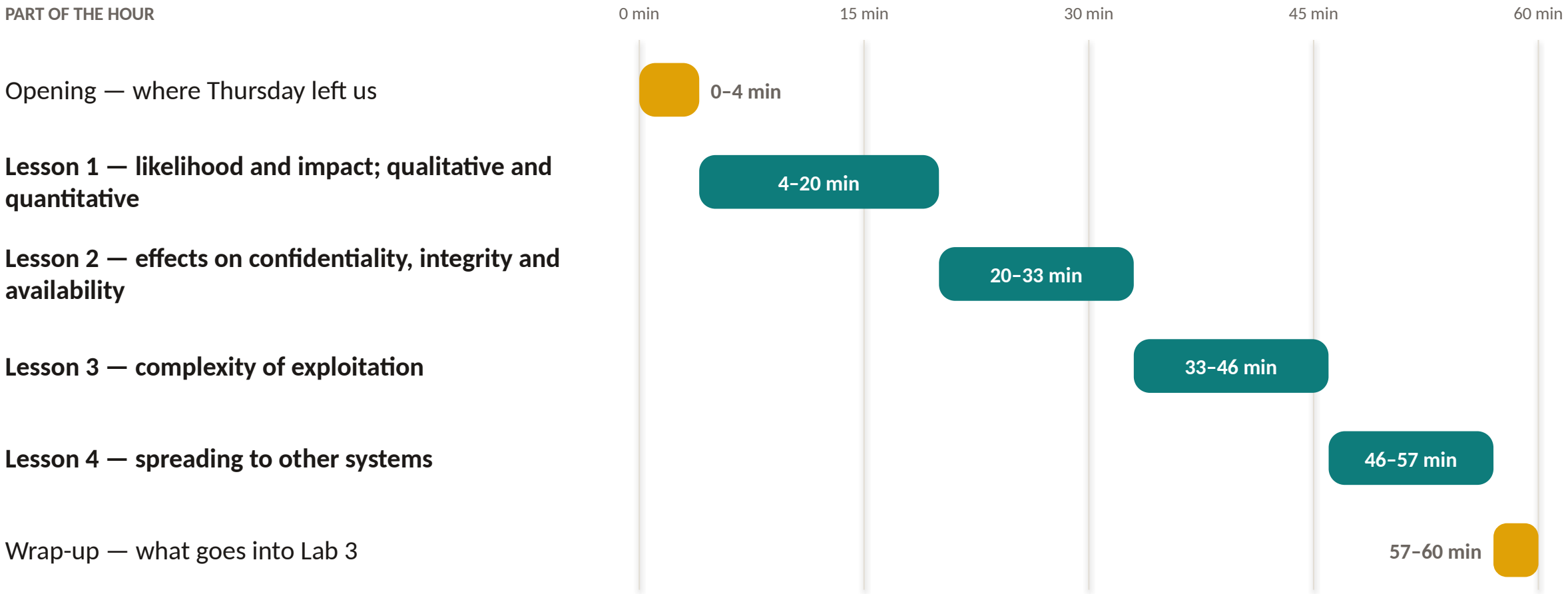
The one fact to remember



A risk is never a single number taken from the air. It is a **likelihood** and an **impact**, each measured on a scale that was defined before the assessment started, and each supported by evidence that another analyst can check.

Every rating in Lab 3 cites its evidence: an incident, a report, a test result or a catalogue entry.

Tonight's hour on the clock



Each lesson ends with a Kalmia example, a script to run, a schematic, five flash-cards and six practice questions.

By the end of this hour you will be able to

- Define **likelihood**, **impact** and **risk**, and read a five-level likelihood scale and impact scale whose criteria two analysts would apply in the same way.
- Carry out a **qualitative risk assessment** on a 5 × 5 matrix and a **quantitative risk assessment** with **AV** (asset value), **EF** (exposure factor), **SLE** (single loss expectancy), **ARO** (annualized rate of occurrence) and **ALE** (annualized loss expectancy), and explain why the two rankings can differ.
- Evaluate, separately, the effect of a scenario on the confidentiality, the integrity and the availability of each type of information, with the three **FIPS** (Federal Information Processing Standards) 199 levels and the high-water mark.
- Rate the **complexity of exploitation** of a risk factor with the four **CVSS** (Common Vulnerability Scoring System) exploitability questions and two threat-intelligence checks: the **KEV** (Known Exploited Vulnerabilities) catalogue and **EPSS** (Exploit Prediction Scoring System).
- Model how far an exploitation can **spread** through a network, measure the **blast radius**, and show how segmentation changes it.

OPENING

KEY TERMS ON THIS SLIDE

- **likelihood**
- **impact**
- **risk**
- **qualitative risk assessment**
- **quantitative risk assessment**
- **complexity of exploitation**

IN THE LECTURE MODULE

Overview › Objectives

Legal and ethical notice — read before running any script



- Fictional case: Kalmia Coffee Roasters Inc. — every person, report and system is invented.
- Tonight's four scripts create, read and change only their own files; nothing is scanned, nothing is attacked.
- Run them only on your own computer or lab virtual machine, in a folder of your own (sections 6.4 and 7).
- Check every link and download first: VirusTotal and Google Safe Browsing (section 14, Annex C).
- Risk-assessment results about a real organization are confidential without time limit (section 7.5).

Full terms — read before the first lab:
Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

Kalmia in one paragraph — and where Thursday left us

- Roastery, office and warehouse in Saint-Laurent; three cafés; 46 employees; about $6.8 million of revenue.
- Nadia Roy (president, risk owner) · Karim Haddad (operations) · Sophie Tremblay (finance and **HR** [human resources]) · Lucas Martin (half-time **IT** [information technology]).
- InfoNord (managed service provider) administers the firewall **FW-HQ** (firewall).
- Incidents 2026: **INC-01** (incident) web shop down · INC-02 fake banking details · INC-03 card-payment outage · INC-04 18,500 loyalty records exported · INC-05 phishing text messages.
- Thursday's workshop: 34 risk factors (**KRF-01** [Kalmia risk factor] to KRF-34) and 5 unknowns, each with its sources.
- Tonight: give each risk factor a likelihood and an impact that someone else can check.

OPENING

IN THE LECTURE MODULE

Overview › Kalmia in one paragraph

1

LESSON 1 OF 4 · MINUTES 4–20 OF THE HOUR



Likelihood and impact scales; qualitative and quantitative risk assessment

Defined scales, the 5 × 5 matrix, and the five values of the quantitative method

Criterion 4.1 — scales that make prioritization possible

From a list of risk factors to a risk

- **Risk factor**: an input that determines the level of risk — threat source, vulnerability, predisposing condition.
- **Risk** = a function of the adverse **impact** if an event occurs and the **likelihood** that it occurs (**NIST** (National Institute of Standards and Technology)).
- **Likelihood**: chance that the threat event happens and causes harm in a defined period (one year).
- **Impact**: magnitude of the harm if it happens.
- Always assess one precise **risk scenario**: source → action → vulnerability → asset → consequence.
- Example: phished employee → shared **NAS** (network-attached storage) password found in a share → **NAS-01** (network-attached storage) shares encrypted → no off-site copy.

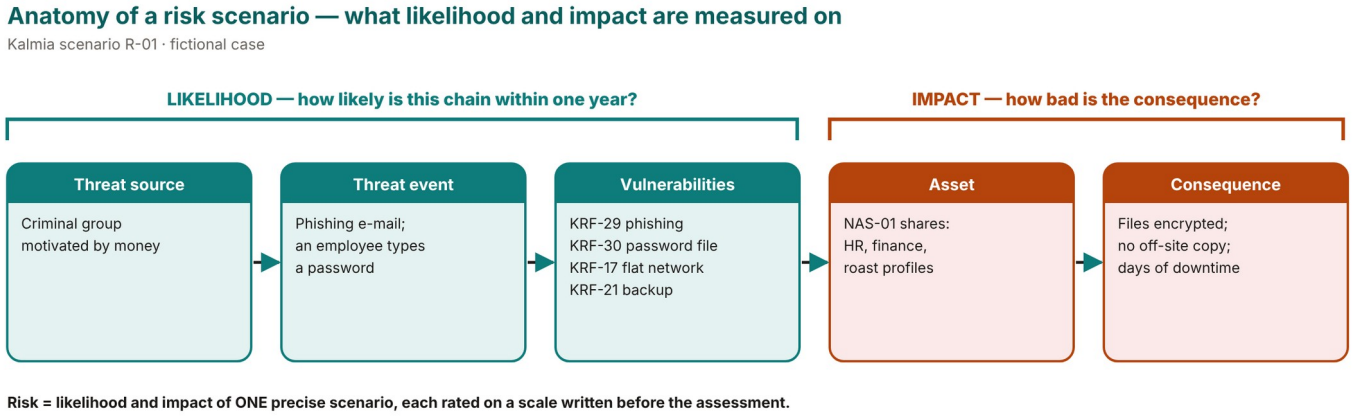


Figure from the lecture module (download it there as SVG or PNG)

Why the scales are written before the assessment

- Undefined words (“high”, “medium”) make two analysts disagree.
- A **likelihood scale** and an **impact scale** are ordered levels with written criteria.
- Approved by management **before** the assessment; unchanged during it.
- Rule 1 — each level has a name and a number.
- Rule 2 — observable criteria: frequency, money, duration, number of records.
- Rule 3 — no overlap: a value falls into exactly one level.
- ISO 31000 and ISO/IEC 27005: the **risk criteria** of the organization.

LESSON 1

Likelihood, impact, two methods

KEY TERMS ON THIS SLIDE

- **likelihood scale**
- **impact scale**
- **before**
- **risk criteria**

IN THE LECTURE MODULE

Lesson 1 › Lecture script › “Why the scales are written before the assessment”

Kalmia's likelihood scale

Level	Name	Frequency anchor	Typical evidence
5	Almost certain	two or more times per year (**ARO** [annualized rate of occurrence] ≥ 2)	It happens repeatedly now; attempts are logged every month
4	Likely	once every two years to twice a year (0.5 ≤ **ARO** [annualized rate of occurrence] < 2)	It happened recently at Kalmia or at similar companies; the weakness is easy to use
3	Possible	once every two to five years (0.2 ≤ **ARO** [annualized rate of occurrence] < 0.5)	It happens in the sector; some conditions must be met
2	Unlikely	once every five to twenty years (0.05 ≤ **ARO** [annualized rate of occurrence] < 0.2)	Controls make success difficult; no recent case
1	Rare	less than once in twenty years (**ARO** [annualized rate of occurrence] < 0.05)	Only in exceptional circumstances



Frequency anchors link the words to numbers.

Kalmia's impact scale

Level	Name	Money (one event)	Operations	Personal information and law
5	Severe	more than $500,000	production or sales stopped more than 3 days	sensitive personal information (financial, health, identity) of more than 1,000 people
4	Major	$100,000 to $500,000	1 to 3 days	personal information of more than 1,000 people; incident reportable to the **CAI** (Commission d'accès à l'information du Québec)
3	Moderate	$25,000 to $100,000	up to 1 day	personal information of 100 to 1,000 people, or confidential business information
2	Minor	$5,000 to $25,000	a few hours, one site	personal information of fewer than 100 people
1	Negligible	less than $5,000	less than one hour	no personal or confidential information



Highest dimension wins: 18,500 loyalty records → 4, even if the cost is $20,000.

The NIST (National Institute of Standards and Technology) example scales: five levels and semi-quantitative values

- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-30 Rev. 1 — example scales in its appendices.
- Five levels: very low · low · moderate · high · very high.
- **Semi-quantitative** values: 0–4 · 5–20 · 21–79 · 80–95 · 96–100 (or 0 · 2 · 5 · 8 · 10).
- Non-adversarial likelihood: more than 100 times a year = very high; 1–10 times = moderate; less than once in 10 years = very low.
- Examples to adapt: the organization chooses its scales (as in **ISO/IEC** [International Organization for Standardization / International Electrotechnical Commission] 27005).
- Still ratings, not measurements: 8 is not “four times” 2.



LESSON 1

Likelihood, impact, two methods

KEY TERMS ON THIS SLIDE

- **Semi-quantitative**

IN THE LECTURE MODULE

Lesson 1 › Lecture script › “The NIST example scales: five levels and semi-quantitative values”

The 5 × 5 risk matrix

- **Risk matrix** (heat map): likelihood × impact → 25 cells.
- Kalmia bands: 1–4 **LOW** · 5–9 **MEDIUM** · 10–16 **HIGH** · 20–25 **CRITICAL**.
- 17, 18 and 19 cannot occur on a 5 × 5 grid.
- Levels are **ordinal**: 4 × 5 = 20 means “top-right area”, not “20 units of risk”.
- Band limits follow the **risk appetite** set by management.
- Class 11 (tomorrow): the complete matrix and the risk register.

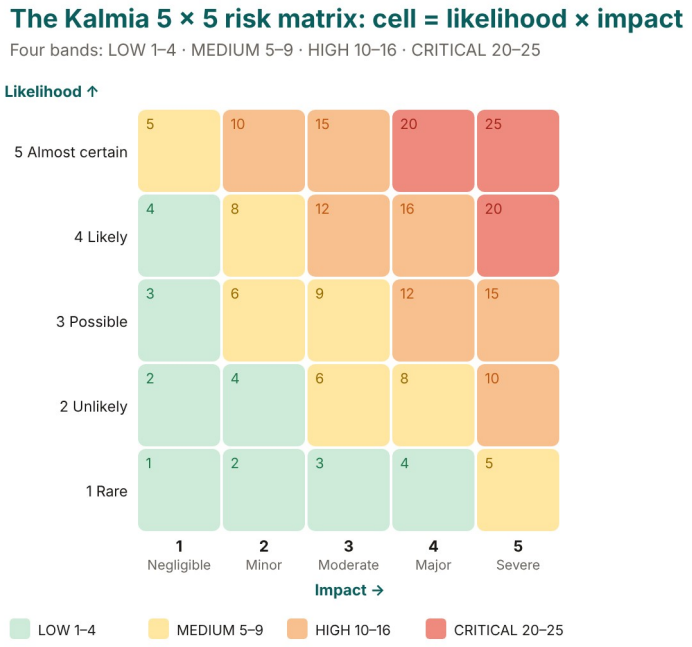


Figure from the lecture module (download it there as SVG or PNG)

Qualitative risk assessment

- **Qualitative risk assessment**: defined categories + a matrix.
- Steps: scenario → evidence → likelihood level → impact level per dimension (keep the highest) → matrix → justification and confidence.
- Strengths: fast; no financial data needed; easy to explain; covers safety and reputation.
- Limits: judgment-based; coarse bands (10 and 16 are both HIGH); cannot price a control.
- Protection against subjectivity: every level cites its evidence.

LESSON 1

Likelihood, impact, two methods

KEY TERMS ON THIS SLIDE

- **Qualitative risk assessment**

IN THE LECTURE MODULE

Lesson 1 › Lecture script › “Qualitative risk assessment”

Quantitative risk assessment (1/2) — the five values

SLE (single loss expectancy) = AV (asset value) × EF (exposure factor)

ALE (annualized loss expectancy) = SLE (single loss expectancy) × ARO (annualized rate of occurrence)

- **Quantitative risk assessment**: money and events per year.
- **AV** (asset value): replacement + rebuild + lost revenue.
- **EF** (exposure factor): fraction of the value lost in one event (0 to 1).
- **SLE** (single loss expectancy) = **AV** × **EF** — loss of one event.
- **ARO** (annualized rate of occurrence): events per year (0.5 = once every two years).
- **ALE** (annualized loss expectancy) = **SLE** × **ARO** — average loss per year.

LESSON 1

Likelihood, impact, two methods

KEY TERMS ON THIS SLIDE

- **Quantitative risk assessment**

IN THE LECTURE MODULE

Lesson 1 › Lecture script › “Quantitative risk assessment (1/2) — the five values”

Quantitative risk assessment (2/2) — a worked example on NAS-01 (network-attached storage)

- Scenario R-01: ransomware encrypts the **NAS-01** (network-attached storage) shares.
- **AV** (asset value) = $250,000 (hardware, rebuilding **HR** [human resources], finance and roast data, lost production days).
- **EF** (exposure factor) = 0.60 — the **USB** (Universal Serial Bus) backup is attached and fails unnoticed (**KRF-21** [Kalmia risk factor]).
- **SLE** (single loss expectancy) = 250,000 × 0.60 = $150,000.
- **ARO** (annualized rate of occurrence) = 0.5 — 9 of 30 staff entered a password in May; flat network.
- **ALE** (annualized loss expectancy) = 150,000 × 0.5 = **$75,000 per year**.
- With a tested off-site backup (**EF** [exposure factor] = 0.10): **ALE** (annualized loss expectancy) = $12,500 → a control under $62,500 a year pays for itself (Topic 6).



LESSON 1

Likelihood, impact, two methods

IN THE LECTURE MODULE

Lesson 1 › Lecture script › “Quantitative risk assessment (2/2) — a worked example on NAS-01”

Qualitative or quantitative? Strengths, limits and the hybrid practice

- Example: café outage = HIGH on the matrix, $3,000 a year; bank fraud = MEDIUM, $10,000 a year.
- Matrix: what deserves attention · money: what each option is worth.
- Hybrid practice: a matrix for every risk, an **ALE** (annualized loss expectancy) for the few that compete for the budget.
- **FAIR** (Factor Analysis of Information Risk) (FAIR Institute): ranges and simulations instead of single numbers.

	Qualitative	Quantitative
Result	levels (LOW to CRITICAL)	money per event and per year
Data needed	criteria and expert judgment	asset values, loss data, frequencies
Speed	fast	slow (data collection)
Main strength	communicates priorities; covers harms that are hard to price	supports cost-benefit decisions and insurance discussions
Main limit	subjective; coarse bands	numbers can look precise without being accurate; rare severe events get a small **ALE** (annualized loss expectancy)

Example 1 — Five Kalmia scenarios scored twice: the first rows of the Lab 3 register

TASK

Using the Kalmia likelihood and impact scales, rate five risk scenarios built from Thursday's workshop list (**KRF** [Kalmia risk factor] rows), place them on the 5 × 5 matrix, then compute the **SLE** (single loss expectancy) and the **ALE** (annualized loss expectancy) of the same scenarios and compare the two rankings.

ID (identifier)	Scenario (risk factors)	L (likelihood)	I (impact)	Score → level	AV (asset value)	EF (exposure factor)	SLE (single loss expectancy)	ARO (annualized rate of occurrence)	ALE (annualized loss expectancy) / year
R-01	Ransomware encrypts the **NAS-01** (network-attached storage) shares (**KRF-29** [Kalmia risk factor], 30, 17, 21)	4	5	20 → CRITICAL	$250,000	0.60	$150,000	0.5	$75,000
R-02	Former employee's account exports loyalty records (KRF-18)	4	4	16 → HIGH	$120,000	0.50	$60,000	0.5	$30,000
R-03	Fraudulent supplier bank change is paid (KRF-22)	3	3	9 → MEDIUM	$40,000	1.00	$40,000	0.25	$10,000
R-04	Café card payments stop — single link (KRF-04)	5	2	10 → HIGH	$3,000	0.25	$750	4	$3,000
R-05	**FW-HQ** (firewall) administration portal taken over (KRF-12)	2	5	10 → HIGH	$300,000	0.40	$120,000	0.1	$12,000

Code example 1 (Python) — kalmia_risk_scoring.py

A Python script that scores the five scenarios with the Kalmia scales, converts each score into a level, computes the **SLE** (single loss expectancy) and the **ALE** (annualized loss expectancy), checks that each likelihood agrees with its **ARO** (annualized rate of occurrence), ranks the scenarios both ways and writes `kalmia_risk_scores.csv`. The visualization places each scenario on the 5 × 5 heat map as soon as its score is computed and grows its **ALE** (annualized loss expectancy) bar.

kalmia_risk_scoring.py — lines 94–105 · every code line has its own comment line

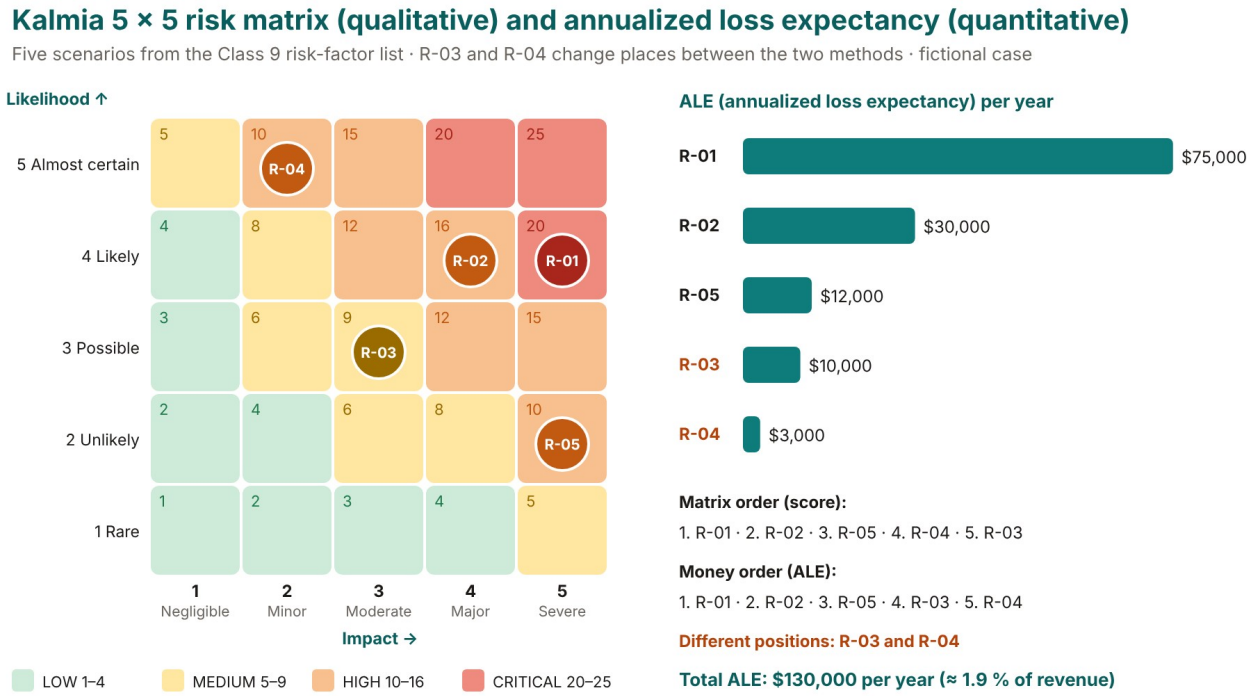
```
 94  # Qualitative score: the matrix cell is likelihood multiplied by impact (an
ordinal convention, not money).
 95  score = lik * imp
 96  # Convert the score into a level with the agreed bands.
 97  level = level_of(score)
 98  # Quantitative step 1: single loss expectancy = asset value x exposure factor.
 99  sle = av * ef
100  # Quantitative step 2: annualized loss expectancy = SLE x annualized rate of
occurrence.
101  ale = sle * aro
102  # Calibration: the likelihood chosen by the analyst must agree with the ARO on
the same scale.
103  expected = likelihood_from_aro(aro)
104  # Keep a short verdict for the report: OK, or the level that the ARO points to.
105  check = "OK" if expected == lik else f"CHECK: ARO {aro} points to level
{expected}"
```

OUTPUT — last 10 of 25 lines (real run)

```
[CHECK] R-05 likelihood 2 vs ARO 0.1 -> OK
[RANK] position | qualitative (score, level)
| quantitative (ALE)
[RANK] 1 | R-01 (20, CRITICAL) | R-01 (75,000
$)
[RANK] 2 | R-02 (16, HIGH) | R-02 (30,000 $)
[RANK] 3 | R-05 (10, HIGH) | R-05 (12,000 $)
[RANK] 4 | R-04 (10, HIGH) | R-03 (10,000 $)
[RANK] 5 | R-03 (9, MEDIUM) | R-04 (3,000 $)
[DIFF] scenarios ranked differently: R-03, R-
04
[TOTAL] expected yearly loss of the 5
scenarios: 130,000 $
[SAVE] kalmia_risk_scores.csv - 5 rows for
the Lab 3 risk register
```

```
python3 kalmia_risk_scoring.py
Runner: lecture module
```

Schematic 1 — The Kalmia 5 × 5 risk matrix with the five scenarios, and their annualized loss expectancy



Left: likelihood (1–5) on the vertical axis, impact (1–5) on the horizontal axis, cell value = L × I with the four bands. Right: **ALE** (annualized loss expectancy) of the same scenarios. R-03 and R-04 swap places between the two methods.

Risk Analysis — CompTIA Security+ SY0-701 — 5.2
Professor Messer · YouTube · 9:13 · checked November 11, 2026

2

LESSON 2 OF 4 • MINUTES 20–33 OF THE HOUR



Effects on the confidentiality, integrity and availability of information

Three separate questions, the **FIPS** (Federal Information Processing Standards) 199 levels, and the high-water mark

Criterion 4.3 — precise evaluation of the effects on C, I and A

Three objectives, three losses

- **Confidentiality**: authorized restrictions on access and disclosure (privacy, proprietary information).
- **Integrity**: no improper modification or destruction; authenticity, non-repudiation.
- **Availability**: timely and reliable access to and use of information.
- Matching losses: **disclosure** · **alteration** · **destruction or denial** — the **DAD** (disclosure, alteration and destruction) triad.
- Source: FIPS 199.

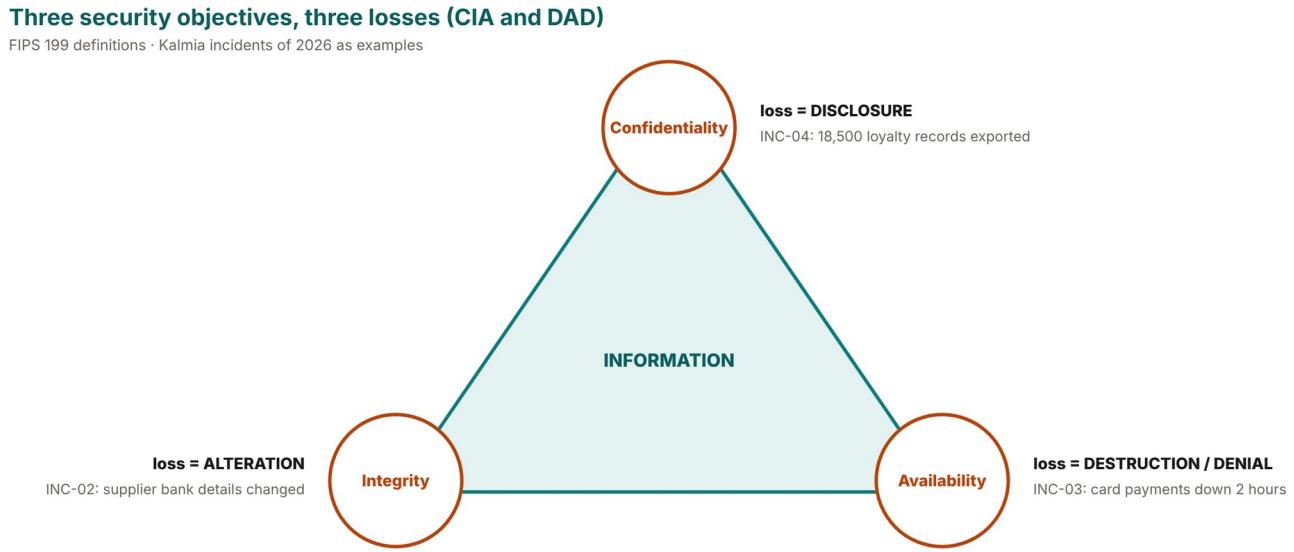


Figure from the lecture module (download it there as SVG or PNG)

Assess each objective separately, for each type of information

- Error to avoid: one impact for a whole incident.
- Three separate questions per information type (criterion 4.3):
  - What is disclosed, and to whom?
  - What is altered or destroyed — would anyone notice?
  - What becomes unavailable, and for how long?
- **INC-04** (incident; 18,500 loyalty records): confidentiality HIGH · integrity NONE · availability NONE.



LESSON 2

Effects on C, I and A

IN THE LECTURE MODULE

Lesson 2 › Lecture script › “Assess each objective separately, for each type of information”

FIPS (Federal Information Processing Standards) 199 — three levels of potential impact

- **SC** (security category) = {(confidentiality, level), (integrity, level), (availability, level)}.
- **High-water mark**: each objective takes the highest level of its information types; the system takes the highest of the three.

FIPS (Federal Information Processing Standards) 199 level	Adverse effect	In practice	Kalmia impact level
LOW	limited	primary functions still performed, with reduced effectiveness; minor damage or loss	2
MODERATE	serious	significant degradation; significant damage, loss or harm (no loss of life)	3
HIGH	severe or catastrophic	one or more primary functions cannot be performed; major damage, loss or harm	4 (5 if survival or safety is at stake)

The same levels are drawn as a figure in the lecture module (Figure 2.2).

Effects on confidentiality

- Measure: type and sensitivity · number of records or people · who obtained it · was it protected (encryption)?
- Disclosed credentials create new scenarios (the attacker logs in as someone else).
- Law 25 (P-39.1): **confidentiality incident** = unauthorized access, use, communication, loss or other breach.
- **Risk of serious injury**: sensitivity · anticipated consequences · likelihood of injurious use (section 3.7).
- Serious risk → notify the CAI and the persons; record every incident in a register.
- Penalties: up to $10 million or 2 % of worldwide turnover (administrative); fines up to $25 million or 4 %.
- Federal (**PIPEDA** (Personal Information Protection and Electronic Documents Act), OPC): real risk of significant harm = sensitivity + probability of misuse.



LESSON 2

Effects on C, I and A

KEY TERMS ON THIS SLIDE

- confidentiality incident
- Risk of serious injury

IN THE LECTURE MODULE

Lesson 2 › Lecture script › “Effects on confidentiality”

Effects on integrity

- Integrity losses are often **silent**: **INC-02** (incident) bank details, a roast temperature, a web-shop price.
- Impact grows with the **detection delay**.
- Detection: compare with a trusted reference — a **cryptographic hash** (**SHA-256** (Secure Hash Algorithm, 256-bit), FIPS 180-4).
- One changed character → a completely different digest.
- **File integrity monitoring**: record digests, compare later.
- Kalmia: an altered charge temperature destroys batches and stresses a roaster that runs above 200 °C.

LESSON 2

Effects on C, I and A

KEY TERMS ON THIS SLIDE

- **silent**
- **detection delay**
- **cryptographic hash**
- **File integrity monitoring**

IN THE LECTURE MODULE

Lesson 2 › Lecture script › “Effects on integrity”

Effects on availability

- Measured in time against the Lab 1 **BIA** (business impact analysis):
- **MTD** (maximum tolerable downtime) — longest interruption a process can survive.
- **RTO** (recovery time objective) — target restore time (shorter than the **MTD** [maximum tolerable downtime]).
- **RPO** (recovery point objective) — maximum data loss, in time (age of the last good copy).
- Card payments: **MTD** (maximum tolerable downtime) 4 h → **INC-03** (incident; 2 h) moderate; 2 days would not be.
- Nightly backup → **RPO** (recovery point objective) up to 24 hours.

Availability over one year	Maximum downtime per year
99 %	87.6 hours (3.65 days)
99.9 %	8.76 hours
99.99 %	52.6 minutes
99.999 %	5.3 minutes

One event, three effects — and the high-water mark

- Ransomware: data copied out (C) · files encrypted (A) · files altered or half-encrypted (I).
- National Cyber Threat Assessment 2025–2026: the most damaging cyber threat to Canadian organizations.
- Assess objective by objective, information type by information type.
- Keep the highest level per objective → the impact columns of the Lab 3 register.
- Controls per effect: Ransomware playbook (ITSM.00.099) — start with an offline backup.



LESSON 2

Effects on C, I and A

IN THE LECTURE MODULE

Lesson 2 › Lecture script › “One event, three effects — and the high-water mark”

Example 2 — One night, three effects: the NAS-01 (network-attached storage) ransomware scenario, objective by objective

TASK

For the ransomware scenario on **NAS-01** (network-attached storage; R-01), determine the effect on the confidentiality, the integrity and the availability of each type of information stored on NAS-01, give each effect a **FIPS** (Federal Information Processing Standards) 199 level, and compute the high-water mark of the incident and the security category of NAS-01.

Information type	Owner's potential impact C / I / A	What happened tonight	Effect C / I / A
HR (human resources) files (staff list, pay data)	HIGH / MODERATE / LOW	a copy is found outside the share	HIGH / NONE / NONE
Finance (supplier banking details)	MODERATE / HIGH / MODERATE	the file is unreadable (.locked)	NONE / not verifiable / MODERATE
Roast profiles	MODERATE / HIGH / MODERATE	charge temperature changed from 200 to 230 °C	NONE / HIGH / NONE
Shared documents	LOW / LOW / LOW	nothing	NONE / NONE / NONE

Code example 2 (Bash) — kalmia_cia_effects.sh

A Bash script that builds the four-share replica in `./nas01_lab`, records a **SHA-256** (Secure Hash Algorithm, 256-bit) baseline, replays the three events of the night inside that folder only, scans again, decides the confidentiality, integrity and availability effect of each file, computes the high-water marks and writes `cia_effects.csv`. The visualization shows the four files, their digests, the event that hits each one, and the **CIA** (confidentiality, integrity and availability) triangle filling in.

kalmia_cia_effects.sh — lines 113–122 · every code line has its own comment line

```
113  while read -r share path digest; do
114      # By default nothing happened to this file.
115      c=NONE; i=NONE; a=NONE; ev="no change"
116      # Confidentiality: a copy with the same name outside the share means
disclosure.
117      if [[ -f "$LAB/_exfil/$(basename "$path")" ]]; then c=${CPOT[$share]};
ev="copy found in _exfil"; fi
118      # Availability: the file is gone or unreadable, so authorized users cannot
use it (integrity cannot be checked).
119      if [[ ! -r "$path" ]]; then a=${APOT[$share]}; ev="file missing or
unreadable - integrity not verifiable"
120      # Integrity: the file is still there but its digest differs from the
baseline.
121      elif [[ "$(hash_of "$path")" != "$digest" ]]; then i=${IPOT[$share]};
ev="SHA-256 differs from the baseline"
122      # Close the if block.
```

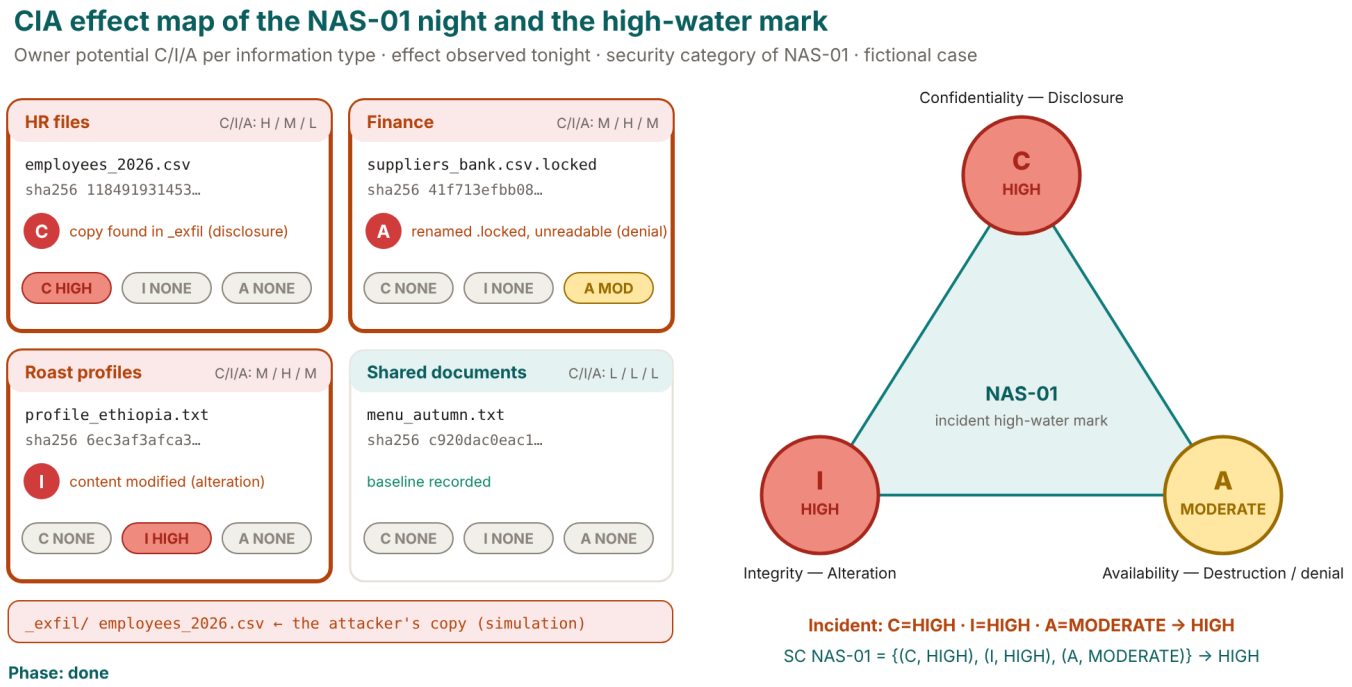
OUTPUT — last 6 of 16 lines (real run)

```
[SCAN] finance/suppliers_bank.csv: C=NONE
I=NONE A=MODERATE -> MODERATE (file missing
or unreadable - integrity not verifiable)
[SCAN] roast/profile_ethiopia.txt: C=NONE
I=HIGH A=NONE -> HIGH (SHA-256 differs from
the baseline)
[SCAN] shared/menu_autumn.txt: C=NONE I=NONE
A=NONE -> NONE (no change)
[INCIDENT] effect: C=HIGH I=HIGH A=MODERATE -
> overall HIGH
[FIPS199] SC NAS-01 = {(confidentiality,
HIGH), (integrity, HIGH), (availability,
MODERATE)} -> HIGH
[SAVE] ./nas01_lab/cia_effects.csv - impact
columns for the Lab 3 risk register
```



`bash kalmia_cia_effects.sh`
Runner: lecture module

Schematic 2 — CIA (confidentiality, integrity and availability) effect map of the NAS-01 (network-attached storage) night and the high-water mark



Each row is an information type stored on **NAS-01** (network-attached storage); each column a security objective. Grey text = owner's potential level; coloured cell = effect observed tonight. The bottom line is the security category of NAS-01 (high-water mark).

The CIA Triad — CompTIA Security+ SY0-701 — 1.2
Professor Messer · YouTube · 5:18 · checked November 11, 2026

Business Impact Analysis — CompTIA Security+ SY0-701 — 5.2
Professor Messer · YouTube · 2:55 · checked November 11, 2026

3

LESSON 3 OF 4 • MINUTES 33–46 OF THE HOUR



Complexity of exploitation of a risk factor

The four **CVSS** (Common Vulnerability Scoring System) exploitability questions, threat evidence, and how controls raise complexity

Criterion 4.5 — accurate assessment of the complexity of exploitation

What “complexity of exploitation” means

- Criterion 4.5: accurate assessment of the complexity of exploitation.
- **Complexity of exploitation** = access, conditions, privileges, user help, skill and tools needed.
- Main input of adversarial likelihood: easier exploitation → higher likelihood.
- **Exploit**: code or technique that uses a vulnerability.
- Public, automated exploit → complexity drops for everyone.



LESSON 3

Complexity of exploitation

KEY TERMS ON THIS SLIDE

- **Complexity of exploitation**
- **Exploit**

IN THE LECTURE MODULE

Lesson 3 › Lecture script › “What “complexity of exploitation” means”

The six questions that measure complexity

1. Where must the attacker be? (**attack vector**)
2. Conditions beyond the attacker's control? (**attack complexity**)
3. Account needed first, with which privileges? (**privileges required**)
4. Must a legitimate user act? (**user interaction**)
5. Already exploited or public exploit? (**KEV** (Known Exploited Vulnerabilities), **EPSS** (Exploit Prediction Scoring System), exploit maturity)
6. Do controls add steps or raise detection? (**MFA** (multi-factor authentication), lockout, monitoring, segmentation)

- Questions 1–4: CVSS v3.1, maintained by **FIRST** (Forum of Incident Response and Security Teams).



LESSON 3

Complexity of exploitation

KEY TERMS ON THIS SLIDE

- **attack vector**
- **attack complexity**
- **privileges required**
- **user interaction**

IN THE LECTURE MODULE

Lesson 3 › Lecture script › “The six questions that measure complexity”

The four exploitability metrics of CVSS (Common Vulnerability Scoring System) v3.1 and their weights

Exploitability = 8.22 × AV (Attack Vector) × AC (Attack Complexity) × PR (Privileges Required) × UI (User Interaction)

- Exploitability = 8.22 × **AV** (Attack Vector) × **AC** (Attack Complexity) × **PR** (Privileges Required) × **UI** (User Interaction) — maximum 3.9 (Network, Low, None, None).
- Base score 0.0–10.0 = exploitability + impact (C, I, A of Lesson 2).
- Severity: none 0.0 · low 0.1–3.9 · medium 4.0–6.9 · high 7.0–8.9 · critical 9.0–10.0.

Metric	Values and weights
Attack Vector — where the attacker must be	Network 0.85 · Adjacent 0.62 · Local 0.55 · Physical 0.20
Attack Complexity — conditions beyond the attacker's control	Low 0.77 · High 0.44
Privileges Required — account needed before the attack	None 0.85 · Low 0.62 · High 0.27 (0.68 and 0.50 when the scope changes)
User Interaction — action of a legitimate user	None 0.85 · Required 0.62

Two real vulnerabilities, two complexities

- Log4Shell — CVE-2021-44228: `AV:N/AC:L/PR:N/UI:N`, scope changed.
- Exploitability 3.9 · base score 10.0 · in the **KEV** (Known Exploited Vulnerabilities) catalogue since December 10, 2021.
- One crafted text string written to a log was enough.
- Spectre v1 — CVE-2017-5753: `AV:L/AC:H/PR:L/UI:N`.
- Exploitability 1.1 · base score 5.6: local code, an account and a timing measurement.
- Same asset → the second is far less likely to be exploited by ordinary criminals.



LESSON 3

Complexity of exploitation

IN THE LECTURE MODULE

Lesson 3 › Lecture script › “Two real vulnerabilities, two complexities”

CVSS (Common Vulnerability Scoring System) v4.0 — what changed

- CVSS v4.0 — November 2023, by **FIRST** (Forum of Incident Response and Security Teams).
- New: **attack requirements** (**AT** (Attack Requirements): none / present) — conditions of the vulnerable system.
- User interaction: none · passive · active.
- Impacts split: vulnerable system vs **subsequent systems** (Lesson 4).
- Score from equivalence classes, not a formula; threat metric **exploit maturity** (attacked, proof-of-concept, unreported).
- The **NVD** (National Vulnerability Database) still publishes many v3.1 vectors: read both.



LESSON 3

Complexity of exploitation

KEY TERMS ON THIS SLIDE

- **attack requirements**
- **subsequent systems**
- **exploit maturity**

IN THE LECTURE MODULE

Lesson 3 › Lecture script › “CVSS v4.0 — what changed”

Beyond CVSS (Common Vulnerability Scoring System): the KEV (Known Exploited Vulnerabilities) catalogue, EPSS (Exploit Prediction Scoring System) and the OWASP (Open Worldwide Application Security Project) factors

- **CVSS** (Common Vulnerability Scoring System) = how hard; not whether anyone is doing it.
- KEV catalogue (**CISA** (Cybersecurity and Infrastructure Security Agency)): evidence of exploitation in the wild.
- Kalmia: CVE-2017-7921 (cameras) added on March 5, 2026.
- EPSS: probability (0–1) of exploitation in the next 30 days, updated daily.
- No **CVE** (Common Vulnerabilities and Exposures)? OWASP Risk Rating: 8 factors scored 0–9 (skill, motive, opportunity, size; discovery, exploit, awareness, detection).
- Average → LOW (< 3) · MEDIUM (3 to < 6) · HIGH (6–9).



LESSON 3

Complexity of exploitation

IN THE LECTURE MODULE

Lesson 3 › Lecture script › “Beyond CVSS: the KEV catalogue, EPSS and the OWASP factors”

Configuration, human and physical factors — and how controls change complexity

- Same four questions for configuration, human and physical factors — stated as a course method, not **CVE** (Common Vulnerabilities and Exposures) scores.
- Phishing: Network + User Interaction Required · closet key: Physical (**PT-04** [penetration-test finding] walked in).
- **MFA** (multi-factor authentication): a stolen password is not enough · lockout: few guesses.
- Segmentation: changes the attack vector · patching: removes the exploit path.
- **FW-HQ** (firewall): exposed to the Internet, yet the hardest factor (InfoNord credentials + **MFA** [multi-factor authentication]).
- Complexity changes over time; low complexity alone is not high risk.



LESSON 3

Complexity of exploitation

IN THE LECTURE MODULE

Lesson 3 › Lecture script › “Configuration, human and physical factors — and how controls change complexity”

Example 3 — Six Kalmia risk factors ranked by how hard they are to exploit

TASK

Describe the exploitation complexity of six risk factors from Thursday's list with the four **CVSS** (Common Vulnerability Scoring System) v3.1 exploitability questions as they apply at Kalmia, compute the exploitability sub-score, classify the complexity, add the threat evidence (a **KEV** (Known Exploited Vulnerabilities) listing, observed attempts, success proven by a test) and derive a suggested starting likelihood for the Lab 3 register.

#	Risk factor	Vector at Kalmia	Exploitability	Complexity	Threat evidence	Suggested L
1	**KRF-09** (Kalmia risk factor) Web shop admin login, no **MFA** (multi-factor authentication), no lockout	`AV:N/AC:L/PR:N/UI:N`	3.9	VERY LOW	none recorded	4
2	KRF-13 Cameras **CAM-HQ-3/4** (camera) with **CVE-2017-7921** (Common Vulnerabilities and Exposures)	`AV:A/AC:L/PR:N/UI:N`	2.8	LOW	**CISA** (Cybersecurity and Infrastructure Security Agency) **KEV** (Known Exploited Vulnerabilities; March 5, 2026)	4
3	KRF-29 Staff enter passwords on phishing pages	`AV:N/AC:L/PR:N/UI:R`	2.8	LOW	**PT-02** (penetration-test finding): 9 of 30 entered a password	4
4	KRF-11/30 **NAS-01** (network-attached storage) admin over **HTTP** (Hypertext Transfer Protocol), password in a shared file	`AV:A/AC:L/PR:L/UI:N`	2.1	LOW	PT-01: admin access in one day	4
5	KRF-31 Server closet key left in the door	`AV:P/AC:L/PR:N/UI:N`	0.9	HIGH	PT-04: tester walked in unchallenged	2
6	KRF-12 **FW-HQ** (firewall) admin portal on the Internet (**MFA** [multi-factor authentication])	`AV:N/AC:H/PR:H/UI:N`	0.7	HIGH	**MR-01** (monitoring report): 41,870 blocked attempts in October	2

Code example 3 (self-contained HTML [HyperText Markup Language] and JavaScript) — kalmia_exploitability.html

A single **HTML** (HyperText Markup Language) page that runs in any browser without installation. It parses each vector, computes 8.22 × **AV** (Attack Vector) × **AC** (Attack Complexity) × **PR** (Privileges Required) × **UI** (User Interaction), classifies the complexity, applies the course rule for the suggested likelihood, ranks the factors, draws a table and a bar chart, and saves `exploitability.csv`. The runner executes its JavaScript step by step and shows the multiplication of each factor.

kalmia_exploitability.html — lines 82–99 · every code line has its own comment line

```
 82  // Compute the exploitability sub-score: 8.22 x AV x AC x PR x UI (maximum 3.887, shown
as 3.9).
 83  function exploitability(m) {
 84    // Multiply the constant by the four weights that correspond to the four values of the
vector.
 85    return 8.22 * W.AV[m.AV] * W.AC[m.AC] * W.PR[m.PR] * W.UI[m.UI];
 86  // End of the function.
 87  }
 88
 89  // Translate the score into a complexity class (course rule): a high exploitability
means a LOW complexity.
 90  function complexity(e) {
 91    // 3.0 or more: anyone with automated tools can do it.
 92    if (e >= 3.0) return "VERY_LOW";
 93    // 2.0 to 2.9: easy for a motivated attacker.
 94    if (e >= 2.0) return "LOW";
 95    // 1.0 to 1.9: needs specific conditions or skills.
 96    if (e >= 1.0) return "MODERATE";
 97    // Below 1.0: needs physical presence, high privileges or rare conditions.
 98    return "HIGH";
 99  // End of the function.
```

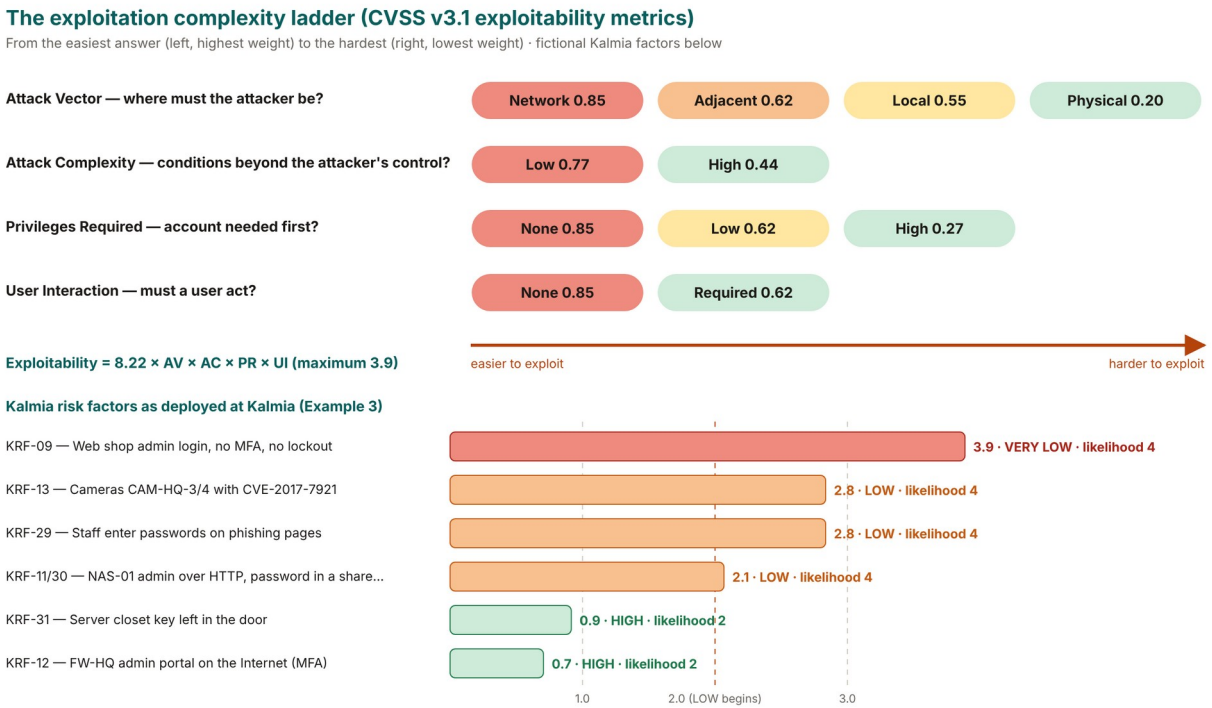
OUTPUT — last 9 of 9 lines (real run)

```
[RESULT] KRF-09    AV:N/AC:L/PR:N/UI:N
exploitability 3.9  VERY LOW  likelihood 4
[RESULT] KRF-13    AV:A/AC:L/PR:N/UI:N
exploitability 2.8  LOW       likelihood 4
[RESULT] KRF-29    AV:N/AC:L/PR:N/UI:R
exploitability 2.8  LOW       likelihood 4
[RESULT] KRF-11/30 AV:A/AC:L/PR:L/UI:N
exploitability 2.1  LOW       likelihood 4
[RESULT] KRF-12    AV:N/AC:H/PR:H/UI:N
exploitability 0.7  HIGH      likelihood 2
[RESULT] KRF-31    AV:P/AC:L/PR:N/UI:N
exploitability 0.9  HIGH      likelihood 2
[RANK] KRF-09 > KRF-13 > KRF-29 > KRF-11/30 >
KRF-31 > KRF-12
[TABLE] 6 rows written
[CHART] 6 bars drawn
```



`open kalmia_exploitability.html in a browser`
Runner: lecture module

Schematic 3 — The exploitation complexity ladder and the six Kalmia risk factors



Top: the four **CVSS** (Common Vulnerability Scoring System) v3.1 exploitability metrics, from easiest (left) to hardest (right), with their weights. Bottom: the exploitability of the six Kalmia factors; the dashed line at 2.0 marks the start of LOW complexity.

Analyzing Vulnerabilities — CompTIA Security+ SY0-701 — 4.3
Professor Messer · YouTube · about 9–10 min · checked November 11, 2026

4

LESSON 4 OF 4 · MINUTES 46–57 OF THE HOUR



Possibility of an exploitation spreading to other systems in the network

Lateral movement, the conditions that allow it, and how to measure a blast radius

Criterion 4.2 — realistic assessment of spreading

Lateral movement, pivoting and propagation

- Criterion 4.2: realistic assessment of spreading.
- **Lateral movement** (ATT&CK TA0008): techniques to enter and control remote systems on a network.
- Examples: Remote Services — **RDP** (Remote Desktop Protocol), **SMB** (Server Message Block) shares, **SSH** (Secure Shell) (T1021); T1210; pass-the-hash (T1550); T1570.
- **Pivoting**: using a compromised system as a launch point.
- **Propagation**: spreading by itself — a **worm** needs no user action.
- **Blast radius**: everything one compromise can affect.



LESSON 4

Spreading to other systems

KEY TERMS ON THIS SLIDE

- Lateral movement
- Pivoting
- Propagation
- worm
- Blast radius

IN THE LECTURE MODULE

Lesson 4 › Lecture script › “Lateral movement, pivoting and propagation”

What makes spreading possible

- **Reachability** — flat **HQ-LAN** (headquarters): every device reaches every device (**KRF-17** [Kalmia risk factor]).
- **Shared or reused credentials** — **NAS** (network-attached storage) admin password shared by four, in a readable file (**KRF-30** [Kalmia risk factor]).
- **Exploitable internal services** — **SMB** (Server Message Block), **RDP** (Remote Desktop Protocol), Telnet, default passwords, no patches (**KRF-07** [Kalmia risk factor], 10, 13).
- **Trust relationships** — **PC-IT-01** (personal computer) administers everything without **MFA** (multi-factor authentication); vendor access; **MSP** (managed service provider) tools.
- **Self-propagating code** — worms.



LESSON 4

Spreading to other systems

KEY TERMS ON THIS SLIDE

- Reachability
- Shared or reused credentials
- Exploitable internal services
- Trust relationships
- Self-propagating code

IN THE LECTURE MODULE

Lesson 4 › Lecture script › “What makes spreading possible”

What limits spreading

- **Segmentation**: zones of similar needs + filtered flows (ITSP.80.022, ITSM.10.092).
- Built with **VLAN** (virtual local area network)s and firewall rules in a small company.
- Unique local admin passwords — Windows LAPS.
- **MFA** (multi-factor authentication) for administration · least privilege · patching · **EDR** (endpoint detection and response).
- Monitoring of east–west traffic.
- **Zero trust** (NIST SP 800-207): no trust from network location.

LESSON 4

Spreading to other systems

KEY TERMS ON THIS SLIDE

- **Segmentation**
- **Zero trust**

IN THE LECTURE MODULE

Lesson 4 › Lecture script › “What limits spreading”

How to assess spreading realistically

- Nodes = assets. Arrow A → B only if **reachability** AND **compromise method**.
- Start from a realistic initial access; follow the arrows **wave by wave**.
- Stop when a wave adds nothing — a **breadth-first search** (**BFS** (breadth-first search)).
- Report: assets reached · criticality reached · waves to the most critical asset.
- Run again with a control → measured value of the control.
- Reachable ≠ compromised · write down every assumption (A-01).

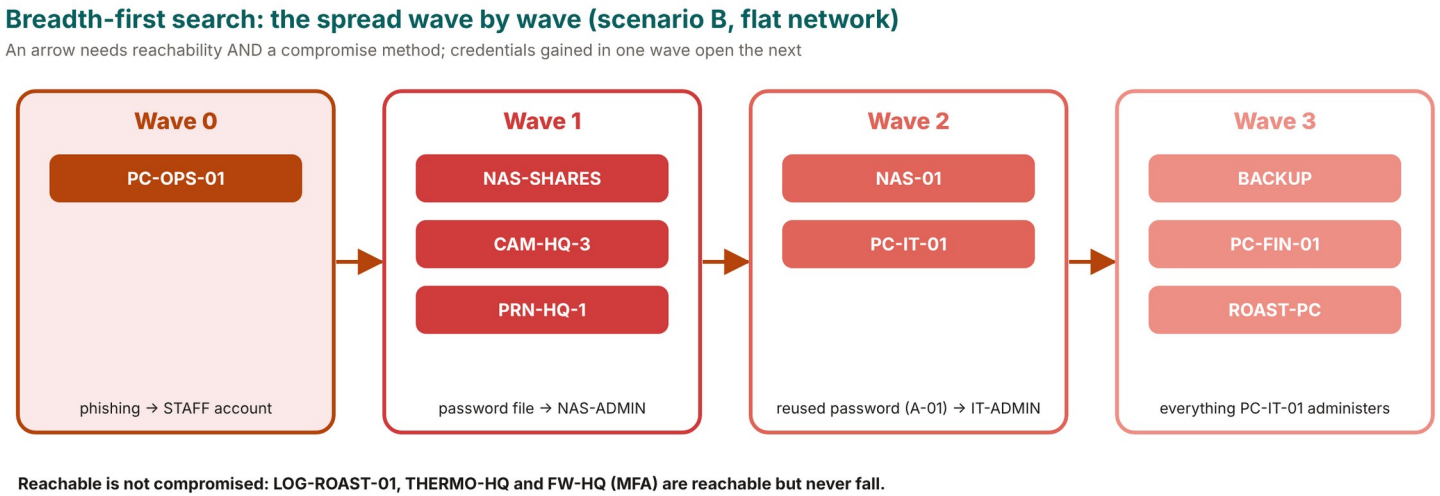


Figure from the lecture module (download it there as SVG or PNG)

WannaCry, 2017 — a worm on flat networks

- March 14, 2017: MS17-010 (critical) patches SMBv1 — CVE-2017-0144.
- May 2017: WannaCry spreads computer to computer, no user action (CISA alert).
- Flat network + missing patch → the whole network.
- Patched, or **SMB** (Server Message Block) filtered between segments → stops at the first machine.
- Spreading possibility belongs in the risk rating.



LESSON 4

Spreading to other systems

IN THE LECTURE MODULE

Lesson 4 › Lecture script › “WannaCry, 2017 — a worm on flat networks”

Example 4 — How far can one phishing click go? Kalmia's blast radius, flat versus segmented

TASK

Model twelve assets of Kalmia's head office, their zones and the ways each one can be taken over. Starting from an outsider on the staff Wi-Fi (scenario A) and from a phished office **PC** (personal computer; scenario B), compute which assets can be reached wave by wave, first on today's flat **HQ-LAN** (headquarters) and then on a segmented design, and compare the blast radius weighted by criticality.

Scenario	Network	Assets reached	Criticality reached	Waves
A — outsider on the staff Wi-Fi	flat (today)	2: **CAM-HQ-3** (camera), **PRN-HQ-1** (printer)	2 / 40 = 5 %	1
A — outsider on the staff Wi-Fi	segmented (Lab 4)	0	0 %	0
B — phished office **PC** (personal computer; **KRF-29** [Kalmia risk factor])	flat (today)	9, including **NAS-01** (network-attached storage), BACKUP, **PC-IT-01** (personal computer), PC-FIN-01, ROAST-PC	32 / 40 = 80 %	3
B — phished office **PC** (personal computer; KRF-29)	segmented (Lab 4)	2: PC-OPS-01, NAS-SHARES	7 / 40 = 17.5 %	1

Code example 4 (Python) — kalmia_spread.py

A Python script that models twelve assets as a graph, decides reachability (flat or segmented) and compromise methods, runs a breadth-first search wave by wave for the two starts and the two designs, prints every takeover with its method and port, and writes `spread_paths.csv` and `blast_radius.csv`. The visualization draws the head-office network and colours each asset when it falls, wave after wave.

kalmia_spread.py — lines 160–175 · every code line has its own comment line

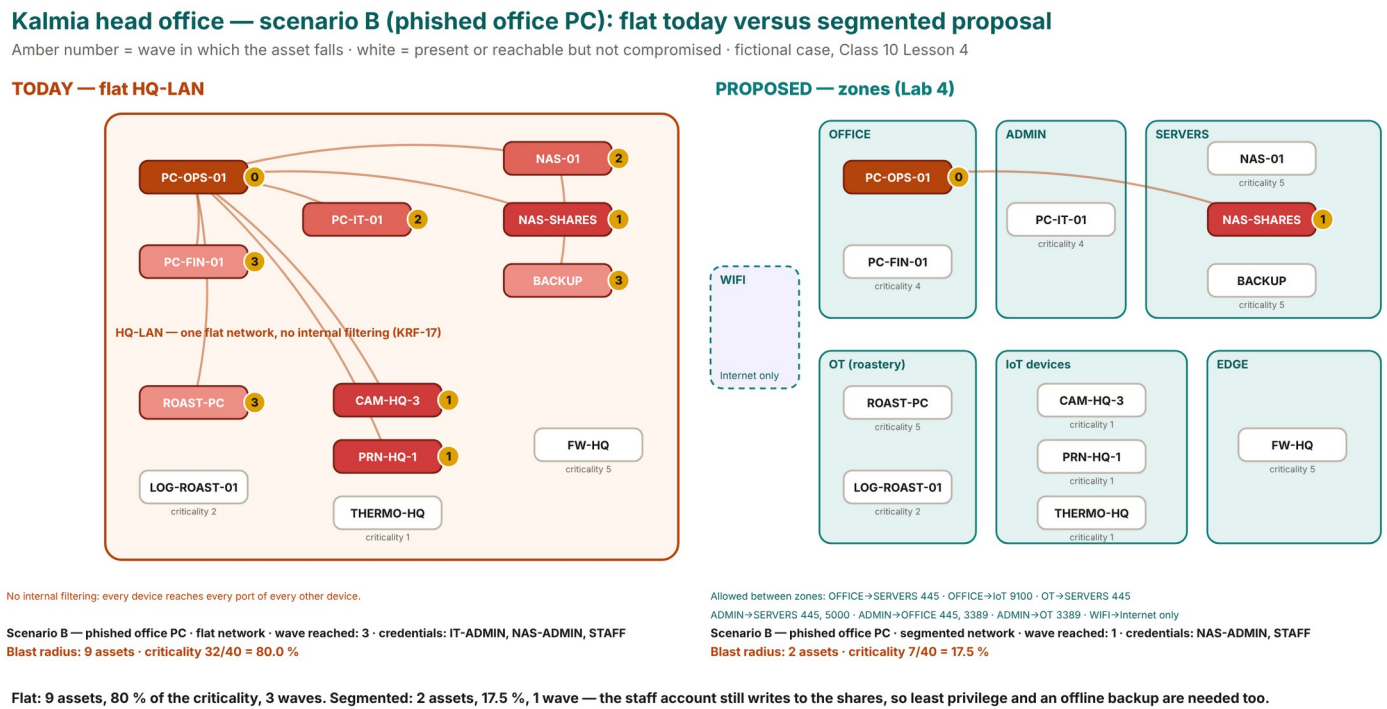
```
160  # Skip the assets already controlled.
161  if dst in owned:
162      # Go to the next asset.
163      continue
164  # Look for a controlled source that can take this asset over.
165  for src in owned:
166      # Data and disks cannot be used to launch an attack.
167      if src in DATA_ONLY:
168          # Try the next source.
169          continue
170      # Ask whether a method exists from this source.
171      how = method_for(design, src, dst, creds)
172      # The first working source is enough.
173      if how:
174          # Record the takeover for this wave.
175          new.append((dst, src, how))
```

OUTPUT — last 9 of 30 lines (real run)

```
[WAVE 3] PC-OPS-01 -> ROAST-PC: RDP with the
IT administrator account [port 3389]
[CREDS] after wave 3: IT-ADMIN, NAS-ADMIN,
STAFF
[RADIUS] B/flat: 9 assets, criticality 32/40
= 80.0%
[RUN] scenario B - start PC-OPS-01 -
segmented network
[WAVE 0] segmented: attacker controls PC-OPS-
01; credentials: STAFF
[WAVE 1] PC-OPS-01 -> NAS-SHARES: SMB share
access with a staff account [port 445]
[CREDS] after wave 1: NAS-ADMIN, STAFF
[RADIUS] B/segmented: 2 assets, criticality
7/40 = 17.5%
[SAVE] spread_paths.csv and blast_radius.csv
```

`python3 kalmia_spread.py`
Runner: lecture module

Schematic 4 — Kalmia head office: flat HQ-LAN (headquarters) today versus the proposed zones (scenario B, phished office PC [personal computer])



Left: today's flat network — wave numbers show when each asset falls (9 assets, 80 % of the criticality). Right: the segmented design — the same start reaches 2 assets (17.5 %). White box = present or reachable but not compromised.

Cyberattack Lateral Movement Explained
Trend Micro Research (Mark Nunnikhoven) · YouTube · about 5 min · checked November 11, 2026

Viruses and Worms — CompTIA Security+ SY0-701 — 2.4
Professor Messer · YouTube · about 6 min · checked November 11, 2026

What you take into Lab 3 (1/2) — four result files

LESSON 1

`kalmia_risk_scores.csv`

likelihood, impact, score, level, **SLE** (single loss expectancy), **ARO** (annualized rate of occurrence) and **ALE** (annualized loss expectancy) of five scenarios

LESSON 2

`cia_effects.csv`

effect on confidentiality, integrity and availability of each information type on **NAS-01** (network-attached storage)

LESSON 3

`exploitability.csv`

vector, exploitability, complexity, evidence and suggested likelihood of six risk factors

LESSON 4

`spread_paths.csv` · `blast_radius.csv`

takeovers wave by wave and the blast radius of each scenario and design

Each file becomes columns of the Lab 3 risk register: likelihood, impact per objective, complexity and spread.

What you take into Lab 3 (2/2) — Lab 3 in short, and what comes next



LAB 3 — SUMMARY ONLY (THE INSTRUCTIONS ARE PUBLISHED SEPARATELY)

Lab 3 — Risk register and prioritization (Integrative Project, Part 3) — assigned Saturday, November 14, 2026 (Class 11), due Friday, November 20, 2026. In short: you will turn Thursday's 34 risk factors into risk scenarios, rate each scenario's likelihood and impact on the Kalmia scales using tonight's evidence (complexity, effects on C, I and A, spreading), place them on the matrix, add an **ALE** (annualized loss expectancy) for the highest risks, and prioritize them. The complete instructions are published separately.



NEXT

Tomorrow, **Class 11 — Topic 5, Part 2**: the organization's ability to respond to an incident, the risk matrix and the risk register, and the prioritization of threats to assets. Quiz 3 (Topics 1 to 5) takes place on Monday, November 16; it is published separately.

Key references (official sites — check each link on VirusTotal before clicking) — thank you

- NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments (September 2012)
  csrc.nist.gov
- ISO/IEC 27005:2022 — Guidance on managing information security risks
  www.iso.org
- FIPS 199 — Standards for Security Categorization of Federal Information and Information Systems (February 2004)
  csrc.nist.gov
- LégisQuébec — Act respecting the protection of personal information in the private sector (P-39.1, as amended by Law 25)
  www.legisquebec.gouv.qc.ca
- FIRST — CVSS v3.1 Specification Document
  www.first.org
- FIRST — CVSS v4.0 Specification Document
  www.first.org
- CISA — Known Exploited Vulnerabilities Catalog
  www.cisa.gov
- FIRST — Exploit Prediction Scoring System (EPSS)
  www.first.org
- OWASP Risk Rating Methodology
  community.owasp.org
- MITRE ATT&CK — Tactic TA0008 Lateral Movement
  attack.mitre.org
- Canadian Centre for Cyber Security — Baseline security requirements for network security zones (ITSP.80.022)
  www.cyber.gc.ca
- Canadian Centre for Cyber Security — National Cyber Threat Assessment 2025–2026
  www.cyber.gc.ca
- Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)
  cyber-soho.github.io

Every link of the lecture — with its explanation and a VirusTotal check link — is in the Links section of the lecture module. Questions?